root CA certificate is usually not sent as part of the chain as the client already has a copy.

> **RECAP** A ***certificate*** contains a public key and identity information of the subject the certificate was issued to and is signed by a ***certificate authority***. A ***certificate chain*** consists of the server or client certificate followed by the certificates of one or more CAs. Each certificate is signed by the CA following it in the chain until a ***root CA*** is reached that is directly trusted by the recipient.

To enable client certificate authentication the server sends a *CertificateRequest* message, which requests that the client also present a certificate, and optionally indicates which CAs it is willing to accept certificates signed by and the signature algorithms it supports. If the server doesn't send this message, then client certificate authentication is disabled. The client then responds with its own Certificate message containing its certificate chain. The client can also ignore the certificate request, and the server can then choose whether to accept the connection or not.

> **NOTE** The description in this section is of the TLS 1.3 handshake (simplified). Earlier versions of the protocol use different messages, but the process is equivalent.

If this was all that was involved in TLS certificate authentication it would be no different to JWT bearer authentication and the server could take the client's certificates and present them to other servers to impersonate the client, or vice versa. To prevent this, whenever the client or server present a Certificate message